

POC FLAG 3 : Kode yang digunakan agar bisa mengakses tempat rahasia

1. Tahap Awal: Enumerasi direktori

Tempat rahasia biasanya merujuk ke file yang lokasinya disembunyikan, dalam artian saya perlu tahu struktur direktori dari website sebelum lanjut ke tahap berikutnya. Di sini saya menggunakan gobuster sebagai tool untuk memudahkan saya mengenumerasi direktori dari web target.

```
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://160.25.222.15:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/combined_directories.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
js (Status: 301) [Size: 318] [==> http://160.25.222.15:8080/js/]
css (Status: 301) [Size: 319] [==> http://160.25.222.15:8080/css/]
backend (Status: 301) [Size: 323] [==> http://160.25.222.15:8080/backend/]
server-status (Status: 403) [Size: 280]
.hta (Status: 403) [Size: 280]
.htaccess (Status: 403) [Size: 280]
.htpasswd (Status: 403) [Size: 280]
index.html (Status: 200) [Size: 5027]
.html (Status: 403) [Size: 280]
.htm (Status: 403) [Size: 280]
. (Status: 200) [Size: 5027]
.htc (Status: 403) [Size: 280]
.html_var_de (Status: 403) [Size: 280]
.html. (Status: 403) [Size: 280]
.html.html (Status: 403) [Size: 280]
.htpasswd (Status: 403) [Size: 280]
.htm. (Status: 403) [Size: 280]
.html (Status: 403) [Size: 280]
```

Berdasarkan hasil scan, ditemukan 3 direktori tersembunyi di mana salah satu folder memiliki penamaan yang krusial. Di sini saya langsung memeriksa folder dari backend dan mendapati directory listing.

Index of /backend

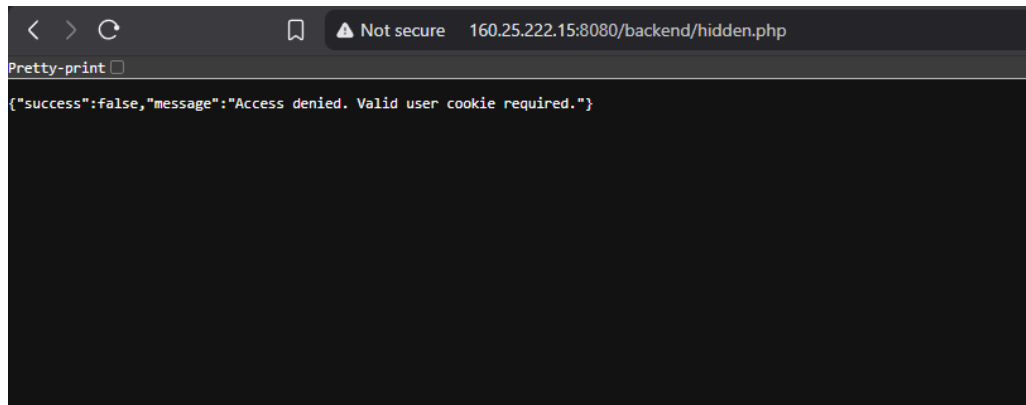
<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 admin.php	2026-04-11 14:06	7.8K	
 admin.php.save	2026-02-16 04:28	6.2K	
 api.php	2026-02-15 15:53	7.9K	
 auth.php	2026-02-16 04:19	4.3K	
 config.php	2026-02-15 12:44	1.2K	
 hidden.php	2026-02-15 11:52	624	

Apache/2.4.65 (Debian) Server at 160.25.222.15 Port 8080

Saya langsung tertuju pada file bernama hidden.php karena dalam Bahasa Indonesia ini berarti “tempat tersembunyi”.

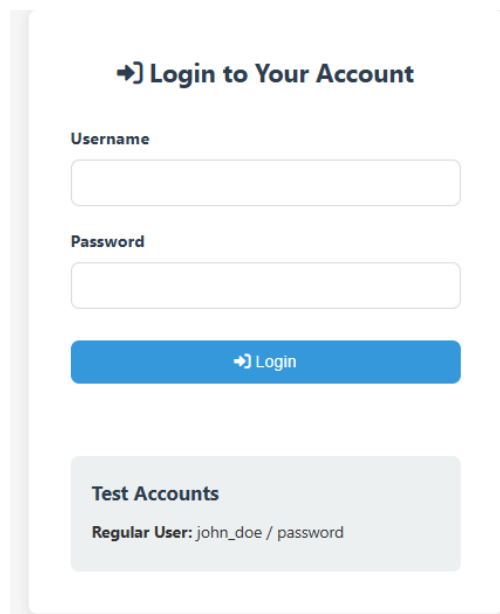
2. Analisis Response Server

Ketika saya mencoba mengakses file tersebut, server mengembalikan pesan error berupa “akses ditolak, membutuhkan cookie valid user”, ini mengindikasikan bahwa server memproses permintaan saya tetapi permintaan belum valid, harus ada manipulasi yang dilakukan di sisi server khususnya pada bagian cookie.



3. Eksekusi

Valid user bisa diinterpretasikan bahwa user haruslah tervalidasi, ini kemungkinan saya harus masuk dalam keadaan teridentifikasi ke sistem yang berarti saya harus login terlebih dahulu.

A login form interface. At the top, it says "Login to Your Account" with a right-pointing arrow icon. Below this are two input fields: "Username" and "Password". Under the "Password" field is a blue button with a right-pointing arrow icon and the text "Login". At the bottom, there is a section titled "Test Accounts" which contains the text "Regular User: john_doe / password".

Di sini saya langsung mencoba menggunakan tes accounts dan mengakses hidden.php lagi.

```
{"success":true,"message":"Congratulations! You found the hidden area.", "hint":"The cookie value that granted you access is the answer to FLAG 3."}
```

Ternyata benar, saya mendapatkan response yang berbeda dibandingkan sebelum login. Di sini saya tinggal melihat cookie apa yang dikirim oleh browser sehingga response server seperti ini.

Name	Value	Do...	Path	Expi...	Size	Http...	Sec...	Sam...	Parti...	Cros...	Prio...
PHPSESSID	ffa1452171b18813a529ebc507d71...	160....	/	Sess...	41	✓					Med...
user_role	user	160....	/	202...	13						Med...
valid_user	true	160....	/	202...	14						Med...

Terdapat 3 cookie dan salah satunya merupakan cookie bawaan PHP. Karena *error message* sebelumnya mengatakan server membutuhkan cookie valid user, saya langsung memasukkan nama dari cookie nomor 3 dan flag diterima.